Project review fixes — 6 September 2026

Implemented fixes for the 18 findings in `project_review_2026-09-05.md`. Changes are in the working tree and have not been deployed.

Changes and regression coverage

Finding	Fix and verification
1. Unsafe kubeconfigs	Shared validation rejects executable authentication providers and local file references before credential validation, scanning, or sandbox provisioning. Tests cover forbidden fields and valid embedded credentials. Kubernetes clients use isolated configuration.
2. AI startup	OpenAI is pinned to 1.55.3 for compatibility with HTTPX 0.28; duplicate client initialization was removed. API import and client construction pass with a dummy key.
3. Worker encryption	API and database-reading workers receive the same encryption key. Required missing keys and decryption failures fail explicitly. Encryption handoff and wrong/missing-key regressions pass.
4. Production authentication	Production requires authentication and validates Keycloak settings at startup. Tests reject disabled authentication and missing verifier settings. Deployment examples include the required configuration.
5. Shared MCP sessions	Server/plugin registries are scoped to a request or scan, enforce an owner, and close after use. Concurrent-user isolation and cleanup tests pass. Raw management routes return HTTP 410; host-profile CloudFox initialization is restricted to anonymous local use.
6. Evidence collisions	Ownership is checked before upload and enforced by the database upsert. Job references must belong to the caller; object keys include a checksum. PostgreSQL tests cover foreign collisions, insertion races, own updates, and foreign jobs.

Finding	Fix and verification
7. Global memory	Memory, notes, tasks, and knowledge queries require tenant/user ownership. Finding identity and resolution distinguish accounts and providers. Migration 17 replaces runtime table creation. PostgreSQL tests cover ownership, notes, task changes, and account-specific resolution.
8. BCDR child operations	Controllers pass verified organization context. Services check parents and linked entities before changes. Routes require BCDR permissions; reorder routes precede parameter routes. Tests cover affected child methods, controller context, and viewer denial.
9. Framework requirements	Create, bulk-create, and update require organization-owned frameworks. Updates and assigned owners are scoped. Shared catalogs remain read-only through these routes. Boundary and controller-context tests pass.
10. Portal management	All six management routes require administrator or compliance-manager roles. Real signed JWT tests reject viewers, auditors, and forged identity headers.
11. Stranded cleanup	Dedicated PostgreSQL advisory-lock sessions lease cleanup. Reconciliation recovers interrupted work and retries provider failures. Already-deleted resources are tolerated; evidence storage failures preserve proof on the lab record. Failure, lease-exclusion, and crash-recovery tests pass.
12. Failed scans	Errors produce failed/partial results and trigger job retry/dead-letter handling. Failed scans cannot resolve memory findings. One result converter preserves findings and errors. Retry, mixed-provider, conversion, and enhanced-memory tests pass.
13. Selected credentials	Explicit AWS/GCP/Kubernetes credentials, including sandbox credentials, are validated and honored. Tests reject foreign/provider mismatches and prevent default fallback for explicit IDs.

Finding	Fix and verification
14. Page navigation	History/schedule HTML shells bootstrap authentication while data APIs remain protected. ASGI tests verify HTML navigation and unauthenticated API rejection.
15. Volatile settings	Custom fields/values, retention policies, and delegations use tenant-scoped Prisma storage. Constraints protect duplicate slugs; transaction locks serialize delegation overlap checks across replicas. Database recreation, ownership, cascade, concurrency, and revocation tests pass.
16. Inactive CI	Four workflows moved to root `.github/workflows` with corrected package, Docker, artifact, and Terraform paths. Python/PostgreSQL and shared/persistence tests were added. Type, test, and Docker failures block validation. Actionlint and local path/shell checks pass.
17. Frontend compilation	Collector mutation branches return response bodies consistently. Final validation also identified and corrected lint errors. TypeScript, configured linters, frontend tests, and production build pass.
18. Quick start	Guides use `docker compose --profile dev up --build` and port 8000. The documented profile includes the API, scheduler, PostgreSQL, and Redis.

Validation results

Check	Result
CloudGuard Python	41 passed
GRC frontend	397 passed in 34 files
GRC shared	67 passed
GRC controls, including PostgreSQL persistence	329 passed
GRC frameworks	152 passed
GRC policies	21 passed
GRC TPRM	12 passed
GRC trust	11 passed
GRC audit	35 passed

Check	Result
Total tests	**1,065 passed**
TypeScript	Frontend and all seven backend/shared projects passed
ESLint	Frontend, controls, and frameworks passed
Frontend production build	Passed, including type checking
CloudGuard database	Migrations 01–17 applied on disposable PostgreSQL 14
GRC database	Fresh schema creation passed; upgrade from the previous schema applied twice, retained an existing policy, and produced no Prisma schema difference
Workflow checks	Actionlint 1.7.7, local path checks, and embedded shell syntax passed
Source/configuration	54 Python files, 31 shell files, nine Compose configurations, and `git diff --check` passed

Stale unit tests were updated to the verified-auth contract, current permission names, and safe storage behavior. The missing Excel fixture is generated in memory. Header-based authentication was not restored.

Previous browser CI jobs used removed `x-user-id`/development-auth bypasses. Those jobs were removed from the active workflow; signed-JWT, RBAC, and tenant-boundary regressions run in backend suites. Full browser coverage still needs a real Keycloak fixture. Existing browser test files remain available for that follow-up.

Python ran with Python 3.11 and the pinned OpenAI version in a temporary dependency directory. Backend tests used a rebuilt shared package. Databases were disposable and separate from application data. Logs are locally available under `/private/tmp/cloudguard-project-review/fix-*`.

Upgrade requirements

1. Reinstall Python dependencies or rebuild API/worker images to use the updated `requirements.txt`.
2. Preserve the API's existing `ENCRYPTION_KEY` and provide that exact value to every worker reading saved credentials. Changing the key does not re-encrypt old credentials.
3. Configure `KEYCLOAK_ISSUER`, `KEYCLOAK_AUDIENCE`, `KEYCLOAK_JWKS_URL`, and browser settings `KEYCLOAK_PUBLIC_URL`, `KEYCLOAK_REALM`, and `CLOUDGUARD_KEYCLOAK_CLIENT_ID`. Production rejects disabled or incomplete authentication.
4. Apply `db/init/17_migration_tenant_memory.sql` before using updated memory endpoints; the existing startup migration runner discovers it automatically. Old memory rows remain unassigned and invisible because they lack trustworthy ownership.

Existing scans can be processed again under verified ownership to populate scoped memory.

5. For existing GRC databases, apply `grc-platform/services/shared/prisma/patches/20260906-p` before starting the updated controls service and regenerate the Prisma client during the build. Fresh installations use `schema.prisma`. Previously in-memory settings cannot be recovered after the old process loses them. Existing database retention policies initially appear as drafts for review.
6. Replace raw MCP initialize/request/tool calls with credential-scoped scan jobs. Those endpoints return HTTP 410. Host-profile CloudFox scanning is unavailable to authenticated multi-tenant callers.
7. GitHub deployment requires `GRC_DEPLOY_ENABLED=true`, AWS/ECR credentials and variables, and `TF_STATE_BUCKET`/`TF_STATE_TABLE` for persistent locked Terraform state. Optional `TF_STATE_REGION` defaults to `AWS_REGION`. Deployment uses the successfully built commit, validates image tags, and stops on Terraform plan errors. Configure repository/environment settings before enabling it.

No live cloud resources were scanned or changed. Docker builds and full Keycloak/browser/cloud end-to-end flows were not run because the Docker daemon was unavailable. Remote security scans, image publishing, and deployment jobs have not executed from this working tree. Existing FastAPI startup-event deprecation and frontend bundle-size warnings remain.